

Microsoft Entra Internal Architecture

When you create an application, Microsoft creates:

Application Object
+
Service Principal



These are two completely different objects in the Entra directory.

App Registrations
=
Application Object



Enterprise Applications
=
Service Principal

Application Object (App Registration)

Technical Purpose

The Application Object defines:

Application Identity



It is the source of truth for application authentication configuration.

Think:

Application Metadata Store



Object Stored In Directory

Application



Directory Object Type:

microsoft.graph.application



What Is Managed Here?

Authentication Configuration

Protocols:

OAuth 2.0
OpenID Connect
SAML Federation



Configuration:

Redirect URI

Front Channel Logout

Implicit Grant

PKCE

SPA Configuration

Native Client Configuration



Credential Configuration

Store:

Client Secrets

Certificates

Federated Credentials



Used by:

Confidential Clients



Example:

Web Applications



Azure Functions

Daemon Apps

Token Configuration

Control token contents.

Example:

Groups Claim



Email Claim

Role Claim

Custom Claims

Affects:

ID Tokens



Access Tokens

API Exposure

Create:

Scopes



Application Roles

Example:

api://employeeportal



Employee.Read

Employee.Write

Allows:

Resource Server Pattern



API Permissions

Configure:

Delegated Permissions



Application Permissions

Example:

User.Read



Mail.Read

Directory.Read.All

Multi-Tenant Configuration

Control:

Single Tenant



Multi Tenant

Personal Microsoft Accounts

Manifest

Directly manipulate:

JSON



appRoles

oauth2Permissions

optionalClaims

groupMembershipClaims

In Technical Terms

App Registration answers:

How does the application authenticate?



How does the application obtain tokens?

What APIs can it call?

What claims exist in tokens?

What credentials does it use?

Service Principal (Enterprise Application)

Technical Purpose

Service Principal defines:

Application Security Principal
inside a tenant



It is the object used during:

Authorization



Access Control

Governance

Monitoring

Directory Object

servicePrincipal



Directory Object Type:

microsoft.graph.servicePrincipal



What Is Managed Here?

User Assignment

Controls:

Who can access application



Example:

John



Sarah

IT Group

Group Assignment

Assign:

Security Groups



Microsoft 365 Groups

Dynamic Groups

Conditional Access Integration

Apply:

MFA



Authentication Strength

Device Compliance

Sign-In Risk

User Risk

to application.

SSO Configuration

Configure:

SAML



Password Vault

Linked Sign-On

OIDC Federation

Provisioning

Configure:

SCIM



User Lifecycle

Group Lifecycle

Example:

Create User



Update User

Disable User

Consent

Manage:

User Consent



Admin Consent

Review:

Granted Permissions



Application Ownership

Assign:

Application Owner



Business Owner

Monitoring

Review:

Sign-In Logs



Audit Logs

Provisioning Logs

Consent Events

Governance

Integrate:

Access Reviews



Entitlement Management

Lifecycle Workflows

Technical Flow

App Registration

Defines:

Identity

Authentication

Token Issuance

Permissions



Enterprise Application

Controls:

Authorization

Governance

Monitoring

Access Control



OAuth Example

Application wants:

User.Read



Configured in:

App Registration



because it defines:

Permission Requirements



Application access should only be allowed for:

IT Department



Configured in:

Enterprise Application



because it defines:

Access Governance



SAML Example

Configure:

Entity ID



Reply URL

Claims

Mostly:

Enterprise Application



because it is a Service Principal integration.

Microsoft Graph Perspective

Retrieve Application Object:

<> http



GET /applications

Returns:

App Registrations



Retrieve Service Principal:

`</> http`



`GET /servicePrincipals`

Returns:

Enterprise Applications



Identity Architect Explanation

Application Object

Application Definition Layer



Responsible for:

Authentication



OAuth

OIDC

Credentials

Permissions

API Exposure

Service Principal

Authorization and Governance Layer



Responsible for:

Assignments



SSO

Provisioning

Conditional Access

Monitoring

Access Reviews

Consent
